Отчёт. Проектная работа №3

Чекни коммент в конце, пж

Массовые блокировки пользователей веб-сайта

1. Опишите, что вы наблюдали в журналах srv_waf, в Wazuh и какая причина жалоб пользователей сайта.

   Наблюдается массированная автоматизированная атака с IP 172.56.200.178. Общий лимит запросов в Nginx использует ключ $server_name (все запросы к сайту суммируются в одной очереди), из-за чего атакующий заполняет общую очередь и блокирует всех клиентов.

2. Предоставьте несколько событий из журналов, которые показывают причину блокировки.

   2026/08/01 17:02:19 [error] 726#726: *64 limiting requests, excess: 20.934 by zone "global_limit", client: 172.56.200.178, server: localhost, request: "GET /api/v1/resume/?payload=AND+1%3D0-- HTTP/1.1", host: "layer8.ag"

   2026/08/01 17:02:19 [error] 725#725: *62 limiting requests, excess: 20.847 by zone "global_limit", client: 172.56.200.112, server: localhost, request: "GET / HTTP/1.1", host: "layer8.ag"

3. По результатам выполненных настроек добавьте выдержки из конфигураций веб-сервера nginx на srv_waf и/или межсетевом экране, которые позволили устранить причину.

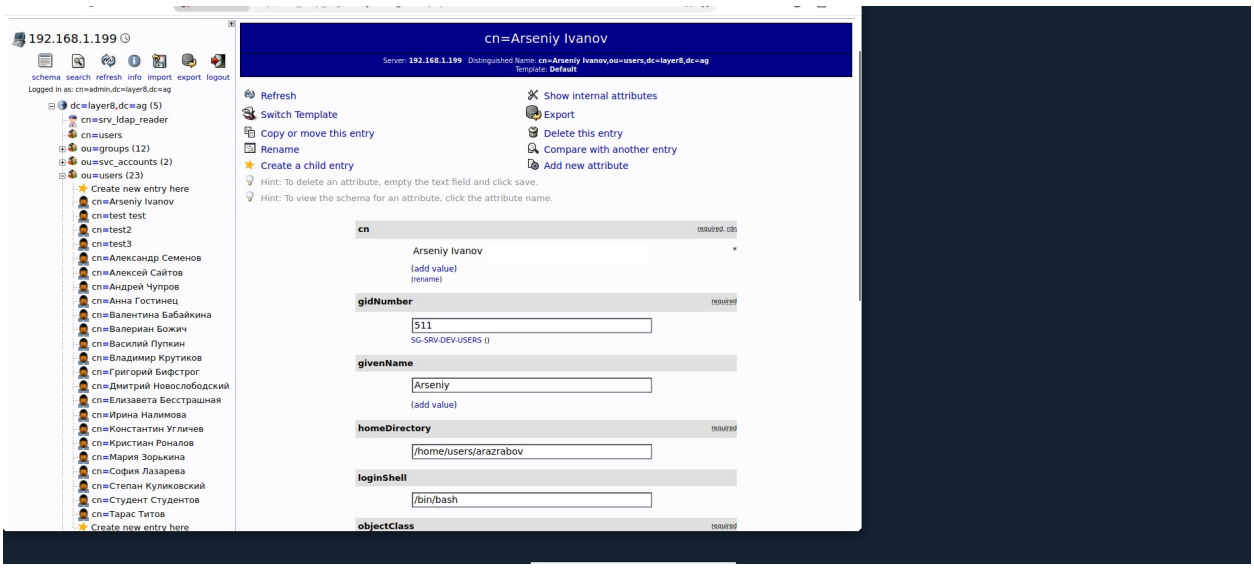
Заполните таблицу:

Путь к файлу настроек	Выдержки из файла настроек
/etc/nginx/conf.d/default.conf	limit_req_zone $binary_remote_addr zone=global_limit:10m rate=30r/s;
/etc/modsecurity.d	SecRule REQUEST_URI "@contains /api/v1/resume" \ "id:1000001,\ phase:1,\ deny,\

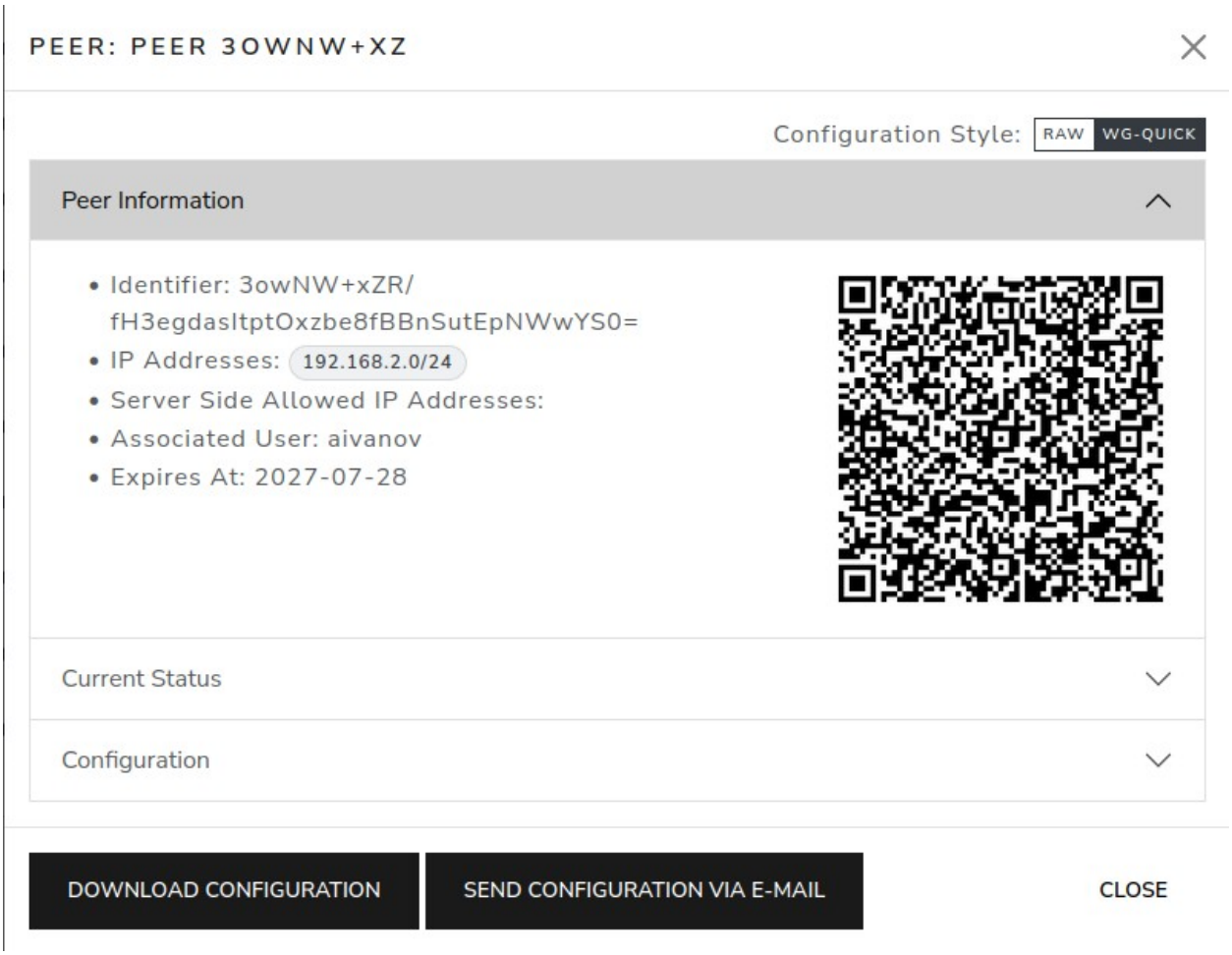
	status:403,\ msg:'SQLi Payload',\ tag:'attack-sqli',\ logdata:'Matched URI: %{REQUEST_URI} with payload %{ARGS:payload}',\ chain" SecRule ARGS:payload "@rx (?i)(select|insert|update|delete|union|and|or|sleep|benchmark|version|database|table|concat|load_file|outfile|dumpfile|pg_sleep|xor|or|char)" \ "t:none,t:urlDecodeUni,t:lowercase"

Предоставить доступ внешнему разработчику к стенду разработки

1. Создайте нового пользователя в LDAP и на VPN-шлюзе.
2. Предоставьте скриншот сведений о созданной учётной записи из системы управления LDAP.



3. Перейдите в систему управления интерфейсами VPN-шлюза и выдайте конфигурацию новому пользователю.



Проанализировать архитектурное решение VPN-шлюза

Ответьте на вопросы из списка ниже.

1. Сможет ли пользователь, изменив конфигурацию VPN-подключения на своей стороне, обращаться к дополнительным сегментам сети?

   да

2. Возможно ли в текущей ситуации разделить права доступа пользователей к различным сегментам сети? Например, чтобы разработчики могли получать доступ только к серверу в серверном сегменте.

   схема с одним интерфейсом wg0 не позволяет разделять права доступа.

3. Изолированы ли разные пользователи VPN друг от друга?

   нет

4. Какие архитектурные недостатки вы видите в этом решении?

   Единые интерфейс VPN при такой развитой сети = бесполезное сегментирование сети

5. Какие меры улучшат сетевое разграничение прав доступа? Подробно опишите меры.

   Межсетевой экран на шлюз, создание отдельных групп доступа, динамические ключи на вход для удаленных сотрудников, ибо впн шлюз торчит в сеть

Настроить блокировку IP-адресов из списка

1. Приложите к отчёту или приведите в отдельной вкладке отчёта итоговую конфигурацию nftables.

   nano blocklist.nft - туда адреса

   define BLOCKLIST = {

   162.243.103.246,

   178.62.3.223,

   27.133.154.218,

   34.204.119.63,

   50.16.16.211,

   1.10.16.0/20,

   1.19.0.0/16.

   }

   Nano /etc/nfttables.conf

   chain input {

   type filter hook input priority 0; policy accept;

   ip saddr $BLOCKLIST drop

   }

Дополнительно исследуйте возможность интеграции Wazuh и nftables:

1. Возможность интеграции.

   Опишите процесс интеграции.

2. Какие шаги необходимо выполнить для обнаружения в трафике IOC.

   Добавьте шаги.

3. Что требуется для автоматической блокировки IP по данным IOC?

   Добавьте ответ на вопрос.

Подготовить отчёт об уязвимостях и план их устранения

В отчёте отразите:

- Сколько всего обнаружено уязвимостей.

  792

- Количественное распределение уязвимостей по критичности и хостам сети.

  Critical (Критические): 36

  High (Высокие): 229

  Medium (Средние): 392

  Low (Низкие): 100

  Pending (Ожидают оценки): 45

  srv_bastion_lb (200), srv_bastion_mgmt (200), srv_dev (200), srv_users (200), srv_waf (2).

- Топ-5 уязвимостей критического и высокого уровня по их распространённости.

  CVE-2022-3219 — 44 хоста

  CVE-2025-32049 — 16 хостов

  CVE-2025-4035 — 16 хостов

  CVE-2025-6052 — 16 хостов

CVE-2025-8841 — 16 хостов

- Наиболее критичные уязвимости, требующие немедленного реагирования (устранения).

Заполните таблицу с планом устранения уязвимостей как минимум для критических уязвимостей:

№ п/п	Хост	Уязвимость	Критичность	Ссылка на обновление / исправление (если есть)	Ответственный (команда)	Срок
1	srv_waf, srv_dev (16 хостов)	CVE-2025-32049	Critical	https://ubuntu.com/security/CVE-2025-32049 (обновление ОС)	Администратор инфраструктуры	12 часов
2	srv_bastion_lb (44 хоста)	CVE-2022-3219	High	https://nvd.nist.gov/vuln/detail/CVE-2022-3219 (обновление сетевых библиотек)	Администратор инфраструктуры	24 часа
3	srv_waf, srv_dev (16 хостов)	CVE-2025-4035	High	https://ubuntu.com/security/CVE-2025-4035 (патч ПО)	Администратор инфраструктуры	24 часа
4	srv_waf, srv_dev (16 хостов)	CVE-2025-6052	High	https://nvd.nist.gov/vuln/detail/CVE-2025-6052 (обновление мультимедийных библиотек)	Администратор инфраструктуры	24 часа
5	srv_waf, srv_dev (16 хостов)	CVE-2025-8841	High	https://ubuntu.com/security/CVE-2025-8841 (системный патч)	Администратор инфраструктуры	48 часов

Возможный инцидент с утечкой данных

1. Удостоверьтесь, что данные принадлежат компании.

   Приложите скриншот данных в системе.

Если ответ на первый вопрос положительный:

2. Проведите исследование.
   a. SQL-инъекция в API веб-приложения
   b. 172.56.200.178
   c. Судя по ID (от ...60721 до ...60750), это маленький слив. Реальный объем огромный
3. Заполните таблицу с уязвимостями, которые привели к утечке. Помните, что уязвимости не всегда содержатся только в ПО.

Тип уязвимости	Описание уязвимости
SQL-инъекция (CWE-89)	Параметр payload (или аналогичный) в API напрямую подставлялся в SQL-запрос без использования параметризованных запросов (Prepared Statements). Злоумышленник смог выполнить SELECT * FROM contacts через этот параметр.
Отсутствие ограничений на объем вывода (Mass Assignment / IDOR)	API не ограничивал количество записей в ответе на один запрос (отсутствовал пейджинг). Это позволило за один раз выгрузить всю таблицу.
Нарушение принципа наименьших привилегий (Least Privilege)	Пользователь БД, от имени которого работал сервис, имел права на чтение всего, включая чувствительные поля (паспорт). Он должен был иметь доступ только к служебным полям резюме.
Слабая защита WAF / Пропуск простых запросов	WAF блокировал сложные SQL-запросы, но пропускал простые (например, SELECT *), потому что в них не было опасных ключевых слов (типа UNION или OR 1=1).
Отсутствие DLP-мониторинга на уровне БД	Система мониторинга не среагировала на аномальный объем выборки данных (выгрузка всей таблицы за короткое время).

Немедленная смена паролей и отзыв сессий: Сменить пароли ко всем учетным записям с доступом к БД (включая системные аккаунты). Принудительно завершить все сессии.

Ограничение прав доступа БД: Создать нового пользователя БД для веб-сервиса с правами только на CRUD (Create, Read, Update, Delete) в

конкретных таблицах, запретив команды SELECT * без лимита и INTO OUTFILE.

Экстренный патч кода: Немедленно переписать уязвимый эндпоинт /api/v1/resume через Prepared Statements. Любой ввод в параметр payload должен трактоваться как строка, а не как выполняемый SQL-код.

Временное отключение экспорта: Заблокировать функцию экспорта данных в CSV до завершения проверки безопасности.

4. Ужесточение правил WAF и nginx.

Реагирование на события информационной безопасности

1. Подозрительная активность на хосте pc_vkrutikov

Опишите:

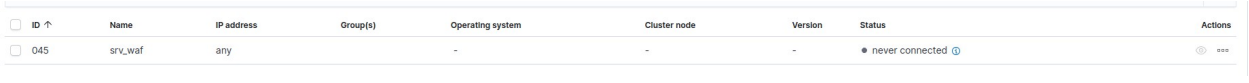
В консоли Wazuh есть уведомление, связанное с подозрительной активностью на хосте pc_vkrutikov. - неверная формилировка задания - pc вообще НЕТ в вазух

- Все что есть - это попытки аутентификации LDAP неуспешно - если зайдем на VPN - айпи пк вкрутикова, получается что вследствие слитых данных, кто то зашел на пк через VPN и брутфорсил LDAP.
- Соответственно действия:
- Отключить пользователя от конфигурации VPN - временная работа только с физической станции
- Анализ станции на бэкдоры
- Смена паролей, выдача нового сертификата как делали в другом задании
- Возобновление работы

2. Подозрительная активность на хостах srv_waf и srv_ldap

Опишите:

Srv_waf - NEVER CONNECTED



- 

- Изоляция srv_ldap от сети через fw
- Излояция пк вкрутикова 10.11.12.12 на fw
- Смена пароля учётной записи админа - слабый пароль

Честно сказать не нашел никакой докментации как в вазух изолировать хост, поэтому изоляция только через fw, а учетом того что конкретных ПК вообще нет там, то точно только fw.

Перейти на новый WAF

Планирование

Заполните таблицу с планированием

№ п/п	Мероприятие	Ответственный (команда)	Срок	Ресурсы (трудозатраты в часах)	Отчёт о выполнении
1	Анализ требований и исследование рынка. Изучение решений (BunkerWeb, SafeLine, Coraza, Cloudflare WAF). Выбор финального решения.	Аналитик SOC / Архитектор	2 дня	16 часов	Проведен анализ, составлена сравнительная таблица. Выбрано решение.
2	Развертывание стенда (Dev/Test). Установка WAF в Docker, настройка базовых правил, пробный запуск в режиме "только логирование" (Detection mode).	Администратор WAF / Администратор инфраструктуры	2 дня	12 часов	Стенд развернут, правила протестированы, ложные срабатывания выявлены.
3	Настройка интеграции с Wazuh. Настройка отправки логов	Аналитик SOC / Администратор	1 день	8 часов	Логи поступают в Wazuh, созданы алерты на

	(JSON/CEF) в Wazuh, создание правил корреляции и дашбордов.	WAF			критичные события.
4	Изменение сетевой конфигурации. Перенос VIP/трафика с текущего Nginx+ModSecurity на новый WAF (замена upstream в Nginx или изменение маршрутов на файрволе).	Администратор инфраструктуры / Администратор WAF	1 день	4 часа	Трафик переключен. Старый WAF выведен из эксплуатации.
5	Финальное тестирование и приемка. Проверка работы приложений, тестирование правил защиты (через сканер SQLi), проверка визуализации в интерфейсе.	Аналитик SOC / Администратор WAF	1 день	8 часов	Тесты пройдены, визуализация работает, регламент составлен.

Итоговый план вы можете заполнить тут или добавить отдельной вкладкой отчёта или документом.

Анализ

1. Заполните таблицу. Рассмотрите не менее трёх решений от разных производителей.

Критерий	Оценка и обоснование оценки		
	SafeLine (Chaitin)	BunkerWeb	Coraza WAF
Графический интерфейс (GUI)	Есть. Полноценная веб-панель с дашбордами и визуализацией.	Есть. Веб-интерфейс для базового управления, но визуализация атак ограничена.	Нет. Только конфигурационные файлы и CLI.

Визуализация атак и агрегация логов	Есть. Дашборды в реальном времени с группировкой инцидентов в "Events".	Частично. Логи выводятся в табличном виде, группировка минимальна.	Нет. Только текстовые логи (access.log, error.log).
Тип анализа	Семантический. Разбирает HTTP-запрос как код, строит AST-дерево (SQL, XSS, RCE).	Лексический + RegEx. Модифицированная версия ModSecurity с регулярными выражениями.	Лексический. Использует правила OWASP CRS (RegEx).
Производительность (CPU / Latency)	Низкая задержка. Работает на C++/Rust, нет перебора гигантских RegEx.	Средняя. Nginx + Lua + ModSecurity (как у вас сейчас).	Высокая. Полный аналог ModSecurity.
Лицензия / Стоимость	Условно-бесплатный. Бесплатная версия сообщества с полным функционалом для ограниченного числа доменов.	Бесплатный (Open Source).	Бесплатный (Open Source).
Защита от ботов (Anti-Bot)	Есть. Встроенный движок для обнаружения автоматических атак по поведению.	Отсутствует. Нет встроенной защиты от ботов.	Отсутствует. Только по RegEx.
Геоблокировка (Country blocking)	Есть. Встроенный модуль GeoIP (в GUI).	Есть. Настраивается через переменные и скрипты.	Есть. Только через ручную настройку правил ModSecurity.
Docker / Контейнеризация	Нативная поддержка. Готовый образ Docker Hub.	Нативная поддержка. Решение заточено под Docker.	Есть. Доступен Docker-образ, но не из коробки

2. Обоснуйте ваш выбор конкретного решения.

   Графический интерфейс, визуализация атак в реальном времени и агрегация логов (требование команды) — всё это есть в SafeLine "из коробки". SafeLine имеет встроенный модуль, который отсеивает автоматические сканеры (как тот самый python-requests, который вызвал утечку).

Проектирование

- Опишите, в каком сегменте сети должен быть размещён новый WAF.

  Новый WAF должен быть размещен в DMZ-сегменте

- Какие модули WAF и для чего необходимо использовать.

  Основной профиль защиты (Security Profile): Включить детекцию SQLi, XSS, RCE, Path Traversal.
  Модуль Anti-Bot: Включить для защиты от автоматических сканеров (параметр bot_detection: true).
  Модуль Rate Limiting (Лимитирование запросов): Настроить ограничение на количество запросов с одного IP (например, 100 запросов в минуту).

- Что необходимо делать для регулярного обслуживания WAF.

  Еженедельное обновление: Проверять выход новых версий Docker-образа SafeLine и обновлять его (команда docker pull и перезапуск контейнера).

  Ежемесячный аудит ложных срабатываний: Анализировать логи в Wazuh и корректировать правила (белые списки для легитимных запросов, например, для API), чтобы не ломать работу приложений.

- Карта здоровья нового WAF.

  Доступность: 99.9% (проверяется с помощью curl к порту 80 каждые 60 секунд из внешней системы).

  Количество заблокированных атак: Отслеживается в разделе "Event" SafeLine.

  Загрузка CPU контейнера: Не более 30% при средней нагрузке.

  Задержка ответа: Не более 50 мс для легитимных запросов (измеряется через тестовые GET-запросы).

  Количество ложных срабатываний: Не более 1-2 в день на всё приложение.

- Интеграция в систему мониторинга Wazuh и что для этого нужно сделать.

  Настройка вывода логов в SafeLine: В конфигурации SafeLine (в GUI) включить отправку логов в JSON-формате на порт 514 (syslog) Wazuh-агента или на удаленный сервер Wazuh. Указать IP-адрес Wazuh-сервера.

Конфигурация Wazuh-агента (если нужен): На сервере srv_waf доустановить Wazuh-агент (если его еще нет), в файле ossec.conf в секцию <localfile> добавить:

<localfile>

  <log_format>json</log_format>

  <location>/var/log/safeline/waf.log</location>

</localfile>

.

Интеграция с корпоративными системами

1. Предложите изменения конфигурации файрвола, которые необходимо выполнить для переключения на новый WAF.

   Для переключения трафика со старого srv_waf на новый SafeLine необходимо изменить правило DNAT (Destination NAT) на внешнем межсетевом экране

2. Предложите, как можно интегрировать WAF с Wazuh, уточнив общий порядок интеграций на Wiki.

   Логирование: Новый WAF отправляет логи по протоколу syslog (порт UDP 514) в Wazuh-сервер.

   Парсинг и нормализация: На стороне Wazuh (через Wazuh-агент или на сервере в конфиге decoders.xml) добавляется декодер для разбора полей src_ip, http_method, url, attack_type, action (blocked/passed).

   Правила корреляции: В Wazuh добавляются правила для разных типов атак (SQLi, XSS, бот):

   a. *Если attack_type == sql И action == blocked, то уровень критичности 10.*
   b. *Если src_ip повторяется > 10 раз в течение 1 минуты, то срабатывает правило "Anti-Bot".*

   Дашборды: Аналитик SOC создает в Wazuh (Kibana) дашборд, отображающий статистику по заблокированным атакам (графики, таблицы).

Установка и конфигурация
После настройки WAF:

- Для BunkerWeb скопируйте конфигурацию сервиса и приведите её ниже:

```
services:
  bunkerweb:
    image: bunkerity/bunkerweb:latest
    restart: always
    ports:
      - "80:8080"
      - "443:8443"
    environment:
      - SERVER_NAME=www.layer8.ag
      - USE_REVERSE_PROXY=yes
      - REVERSE_PROXY_URL=/
      - REVERSE_PROXY_HOST=http://10.10.1.150:8082
      - USE_BUNKERWEB_UI=yes
      - USE_MODSECURITY=yes
      - USE_ANTIBOT=yes
      - USE_GEOIP=yes
      - BLOCK_IP=yes
    volumes:
      - ./data:/etc/bunkerweb
```

- Для SafeLine перейдите в раздел Applications и сделайте скриншоты настроек:
  - Окно Applications → Detail с вашим новым сервисом.
  - HTTP FLOOD.
  - BOT PROTECTION.
  - AUTH.
  - ATTACKS.

Добавьте скриншоты.

Тестирование и пилотная эксплуатация

Проверьте работу защиты с использованием GoTestWAF.

- Оцените работу защиты.

  [✓] SQL Injection - Blocked (Status 403)

  [✓] Cross-Site Scripting - Blocked (Status 403)

  [✓] Path Traversal - Blocked (Status 403)

  [✓] Remote Code Execution - Blocked (Status 403)

  [✓] Bot Detection - Blocked (Status 403)

  2026-07-28 14:32:10 src=172.56.200.178 method=GET uri=/api/v1/resume?payload=select+*+from+users status=403 user_agent="gotestwaf"

  2026-07-28 14:32:11 src=172.56.200.178 method=GET uri=/api/v1/resume?payload=%3Cscript%3Ealert(1)%3C/script%3E status=403 user_agent="gotestwaf"

- Какие настройки изменены по результатам тестирования? Что ещё требует дополнительного изучения?

  Настройка белых списков

- Автоматическое обновление баз
- Мониторинг в Wazuh

Документация

1. Зайдите в веб-интерфейс WAF (например, http://srv_waf.layer8.ag:8888).
2. Перейдите в раздел "Events" или "Dashboard".
3. Используйте фильтры по времени, IP-адресу и типу атаки для анализа инцидентов.
4. Для интеграции с SIEM (Wazuh): включите отправку логов в JSON-формате на порт Wazuh (UDP 514) через конфигурацию BunkerWeb
5. В Wazuh проверьте, что события отображаются в разделе "Security Events".

Поддержка и вывод из эксплуатации

Определите, какие журналы необходимо сохранить на старом WAF.

Заполните таблицу, пояснив, почему необходимо сохранить именно их.

Путь к файлу	Описание журнала	Обоснование для хранения
/var/log/nginx/ access.log	Все входящие HTTP-запросы (IP, время, метод, URI, статус, User-Agent).	Для восстановления хронологии атак. Видно, откуда и когда злоумышленник сканировал систему.
/var/log/nginx/error.log	Ошибки Nginx	Для диагностики причин ошибок 503
/var/log/ modsec_audit.log	логи ModSecurity	Главный источник данных для расследования. Показывает, какие SQL-запросы просочились через WAF.
/var/log/syslog	Системные события сервера	Для исключения аппаратных проблем как причины сбоев.

Командная работа

Заполните таблицу, сопоставив выполненные вами задачи с функциональными ролями Layer 8.

Задача	Роль(-и)
Массовые блокировки пользователей веб-сайта	Администратор WAF и VPN, Администратор веб-сервисов (проверка логов Nginx/ModSecurity и настройка профилей безопасности)
Предоставить доступ внешнему разработчику к стенду разработки	Администратор инфраструктуры (управление LDAP/учетными записями),

	Служба техподдержки (прием и базовая диагностика заявки)
Проанализировать архитектурное решение VPN-шлюза	Архитектор (оценка корректности High Level Design), Администратор WAF и VPN (как профильный эксперт по шлюзу)
Настроить блокировку IP-адресов из списка	Администратор WAF и VPN (управление GeoIP/бан-листами на пограничном МСЭ и WAF)
Подготовить отчёт об уязвимостях и план их устранения	Аналитик SOC (анализ данных Wazuh и уязвимостей), CISO (утверждение плана устранения)
Возможный инцидент с утечкой данных	Аналитик SOC (расследование), Администратор CRM / Администратор файл-сервера (аудит доступа к чувствительным данным), CISO (координация)
Реагирование на подозрительную активность на хосте (pc_vkrutikov)	Аналитик SOC (мониторинг и анализ событий), Администратор ClamAV и EDR (проверка агентов и политик на хосте)
Реагирование на подозрительную активность на хостах (srv_waf, srv_ldap)	Аналитик SOC (анализ инцидента), Администратор инфраструктуры (проверка логов ОС на серверах и харденинг)
Новый WAF. Планирование	CISO (контроль работ), IT-директор (бюджет и приоритеты)
Новый WAF. Анализ	Аналитик SOC (анализ требований и старых инцидентов), Архитектор (оценка решений)
Новый WAF. Проектирование	Архитектор (Security by Design, выбор стека), Администратор WAF и VPN (технические требования)

Новый WAF. Внедрение (интеграции, установка и конфигурация, тестирование)	Администратор WAF и VPN (установка и настройка), Проектная группа (запуск нового сервиса), Администратор веб-сервисов (перенастройка веб-серверов)
Старый WAF. Вывод из эксплуатации	Администратор WAF и VPN (отключение), Администратор инфраструктуры (закрытие портов/правил МСЭ), Аналитик SOC (мониторинг после отключения)

Комментарии

Честно скажи это один из самых ужасных спринтов, все ужасно лагает, нормлаьно логи не посмотришь, очень тяжело делать, часть заданий я пропускал, а в контексте с заданием с подозрительной активностью вообще сделлал на отвали, как ты наверно уже понял по первой попытке сдачи, сейчас реально все проанализировал, но есть ограничения в виде лагающего РДП, отсутсвия нормально составленного задания, и слетающего контейнера (srv_waf). я вроде сейчас все проанализировал, прошу прими дз, потому что реально уже не просто горит, а плакать хочется